Referência da API

Documentação técnica - Prumo

Base local: `http://localhost:4000`. Arquitetura do backend: ../README.md. Especificação importável: openapi.yaml.

Convenções

- Rotas protegidas exigem `Authorization: Bearer <token>`.
- Corpo JSON com `Content-Type: application/json`. Upload de manual usa `multipart/form-data` (não defina o boundary manualmente).
- IDs de rota são inteiros. Datas são strings ISO 8601.
- Exclusão bem-sucedida retorna `204` sem corpo.
- Erros retornam `{ "message": "descrição" }`.

Perfis

Código	Significado	Nesta documentação
`usuario`	Operador	Autenticado
`gerente_setor`	Gerente restrito aos próprios setores (um ou mais)	Gerência
`editor_conteudo`	Editor de conteúdo: publica manuais e provas e vê o painel em todos os setores, sem administrar cadastros	Gerência
`suporte`	Administração global	Suporte, Gerência
`gerente`	Legado; ainda aceito pelos middlewares, mas o banco não permite gravá-lo	—

Gerência = `gerente_setor`, `editor_conteudo` ou `suporte`. **Suporte** = só `suporte`.

Endpoints

Método e rota	Acesso	Documento
`GET /health`	Público	HEALTH.md
`POST /api/auth/login`	Público	AUTH.md
`GET /api/auth/me`	Autenticado	AUTH.md
`PUT /api/auth/password`	Autenticado	AUTH.md
`POST /api/auth/register`	Suporte	AUTH.md
`GET /api/users`	Suporte	USERS.md
`PUT /api/users/{id}`	Suporte	USERS.md
`DELETE /api/users/{id}`	Suporte	USERS.md
`GET /api/sectors`	Gerência	SECTORS.md
`POST /api/sectors`	Suporte	SECTORS.md
`GET /api/systems`	Autenticado	SYSTEMS.md
`POST /api/systems`	Suporte	SYSTEMS.md
`PUT /api/systems/{id}`	Suporte	SYSTEMS.md
`DELETE /api/systems/{id}`	Suporte	SYSTEMS.md
`GET /api/manuals`	Autenticado	MANUALS.md
`GET /api/manuals/manage`	Gerência	MANUALS.md
`GET /api/manuals/{id}`	Autenticado com visibilidade	MANUALS.md
`POST /api/manuals`	Gerência	MANUALS.md
`PUT /api/manuals/{id}`	Gerência (gerente de setor só nos manuais que são só dos seus setores)	MANUALS.md
`DELETE /api/manuals/{id}`	Gerência (mesma regra)	MANUALS.md
`GET /api/uploads/config`	Gerência	UPLOADS.md
`POST /api/uploads/presign`	Gerência	UPLOADS.md
`GET /uploads/{pasta}/{arquivo}`	Público	MANUALS.md
`GET /api/progress/report`	Gerência	PROGRESS.md
`GET /api/progress/{manualId}`	Autenticado com visibilidade	PROGRESS.md
`PUT /api/progress/{manualId}`	Autenticado com visibilidade	PROGRESS.md
`POST /api/exams`	Gerência	EXAMS.md
`GET /api/exams/available`	Autenticado	EXAMS.md
`GET /api/exams/results`	Gerência	EXAMS.md
`GET /api/exams/{id}`	Colaborador do setor da prova	EXAMS.md
`POST /api/exams/{id}/start`	Colaborador do setor da prova	EXAMS.md
`POST /api/exams/{id}/submissions`	Colaborador com a prova em andamento	EXAMS.md
`POST /api/exams/{id}/leave`	Colaborador com a prova em andamento	EXAMS.md
`GET /api/branding`	Público	BRANDING.md
`PUT /api/branding`	Suporte	BRANDING.md

Códigos de resposta

Código	Uso
`200`	Consulta ou atualização concluída
`201`	Recurso criado
`204`	Sucesso sem corpo
`400`	Dados inválidos ou regra de negócio
`401`	Token ausente, inválido ou expirado; credenciais inválidas
`403`	Perfil sem permissão
`404`	Recurso inexistente, sem visibilidade ou rota desconhecida
`409`	Exclusão de sistema com manuais vinculados
`429`	Login bloqueado por excesso de tentativas
`500`	Erro interno, banco indisponível ou identificador duplicado

API de saúde

Documentação técnica - Prumo

`GET /health`

Acesso: público.

Confirma que o processo HTTP está respondendo. Não consulta PostgreSQL nem armazenamento.

Resposta `200`:

```
{ "status": "ok", "service": "Prumo API" }
```

Use no health check de **vida** (reiniciar o processo se não responder).

`GET /health/ready`

Acesso: público.

Executa `SELECT 1` no PostgreSQL. Use no health check de **prontidão** (decidir se a instância recebe tráfego).

Resposta `200`:

```
{ "status": "ok", "database": "ok" }
```

Resposta `503` quando o banco não responde:

```
{ "status": "unavailable", "database": "indisponivel" }
```

API de autenticação e sessão

Documentação técnica - Prumo

Base: `/api/auth`.

`POST /login`

Acesso: público.

```
{ "identificador": "admin", "senha": "admin123" }
```

Fluxo: valida os campos; verifica bloqueio para a combinação IP + identificador; busca o usuário por `identificador` (ou pelo `email` legado); compara o hash bcrypt. Cada falha conta uma tentativa; na quinta, o login fica bloqueado por 15 minutos. Em caso de sucesso, zera as falhas, grava auditoria `login` e emite o JWT.

Resposta `200`:

```
{
  "token": "eyJ...",
  "user": { "id": 1, "nome": "Suporte Admin", "identificador": "admin", "role": "suporte", "sector_ids":
[], "setores": [] }
}
```

O JWT expira em 8 horas e contém `id`, `nome` e `role`. Os setores não ficam no token: são lidos do banco a cada requisição, então mudar os setores de um usuário vale na hora.

Erros: `400` campos ausentes · `401` credenciais inválidas · `429` bloqueado · `500` sem `JWT_SECRET` configurado.

`GET /me`

Acesso: autenticado.

Retorna `id`, `nome`, `identificador`, `email`, `role`, `sector_ids` (lista de ids), `setores` (lista de `{ id, nome }`, em ordem alfabética) e `created_at` do usuário do token. O frontend usa esta rota ao recarregar a página.

`PUT /password`

Acesso: autenticado. Troca a própria senha.

```
{ "currentPassword": "admin123", "newPassword": "NovaSenha2026" }
```

Fluxo: exige nova senha com 8+ caracteres, uma letra e um número; confere a senha atual; grava o novo hash; registra auditoria `password_changed`.

Respostas: `204` sucesso · `400` senha atual incorreta ou nova senha fraca.

`POST /register`

Acesso: suporte. Cria usuário.

```
{
  "nome": "Maria Silva",
  "identificador": "maria.silva",
  "senha": "Treino2026",
  "role": "usuario",
  "sectorIds": [3, 5]
```

```
}
```

- `role`: `suporte`, `editor_conteudo`, `gerente_setor` ou `usuario` (padrão `usuario`).
- `sectorIds`: ids dos setores (um ou mais). Obrigatório para `usuario` e `gerente_setor`; opcional para `editor_conteudo` e `suporte`. Os setores precisam existir (são criados em `POST /api/sectors`).
- Senha segue a mesma política da troca de senha.

Respostas: `201` com o usuário sem senha · `400` campos ausentes, perfil inválido ou senha fraca · `403` sem permissão · `500` identificador já existente.

API de usuários

Documentação técnica - Prumo

Base: `/api/users`. **Acesso:** suporte em todas as rotas. Para criar usuário, ver AUTH.md.

GET /

Lista usuários em ordem alfabética: `id`, `nome`, `identificador`, `email`, `role`, `sector_ids`, `setores` (`{ id, nome }`), `created_at`. A senha nunca é retornada.

POST /import

Cadastro em massa a partir de uma planilha (a tela Usuários lê o CSV e envia as linhas). Até 500 linhas por vez.

```
{
  "dryRun": true,
  "rows": [
    { "linha": 2, "nome": "Ana Paula", "login": "ana.paula", "perfil": "Usuário comum", "setores": "Centr
al de atendimento", "senha": "" }
  ]
}
```

- `perfil`: `Usuário comum`, `Gerente de setor`, `Editor de conteúdo` ou `Suporte` (também `usuario`, `gerente_setor`, `editor_conteudo`, `editor`, `suporte`), sem diferenciar acentos e maiúsculas. Vazio vira `usuario`.
- `setores`: nomes de setores já cadastrados, separados por vírgula. Operador e gerente precisam de pelo menos um.
- `senha`: opcional. Informada, precisa seguir a política; vazia, o servidor gera uma provisória (5 letras e 3 números, sem caracteres que se confundem).

Cada linha volta com `status` (`ok` ou `erro`) e `erro` (login vazio, repetido na planilha ou já cadastrado, perfil desconhecido, setor inexistente, sem setor, senha fraca).

- `dryRun: true`**:** só confere. **Resposta:** `200` com `total`, `validos` e `rows`.
- **Sem** `dryRun`**:** grava numa transação só as linhas válidas e registra auditoria `users_imported`. **Resposta:** `201` com `criados`, `rows` e `acessos` (`nome`, `login`, `perfil`, `setores`, `senha`). `senha` traz a provisória gerada, ou `null` quando veio da planilha. É a única vez que essas senhas aparecem.

Respostas de erro: `400` sem linhas ou mais de 500 · `409` login cadastrado por outra pessoa durante a importação (nada é gravado).

PUT /{id}

Atualiza dados administrativos e substitui a lista de setores. `nome`, `identificador` e `role` são obrigatórios; `sectorIds` é obrigatório (com pelo menos um setor) para operador e gerente de setor. `senha` é opcional: quando enviada, precisa ter 8+ caracteres, uma letra e um número, substitui a senha do usuário (o suporte não precisa saber a atual) e registra auditoria `password_reset` com o id de quem alterou. Vazia ou ausente mantém a senha.

```
{ "nome": "Maria Silva", "identificador": "maria.silva", "role": "gerente_setor", "sectorIds": [3, 5], "s
enha": "NovaSenha2026" }
```

Respostas: `200` usuário atualizado · `400` campos ou perfil inválidos, nenhum setor, setor inexistente ou senha fraca · `404` usuário inexistente.

A mudança de setores vale na hora. A mudança de perfil só vale a partir do próximo login (o perfil fica no token).

`DELETE /{id}`

Respostas: `204` excluído · `400` tentativa de excluir a própria conta.

Atenção: a exclusão apaga em cascata o progresso, as entregas de provas e o histórico de progresso do usuário. Manuais criados por ele e registros de auditoria ficam com o autor nulo.

Limitações

- Não há rota para o suporte redefinir a senha de outro usuário.
- Não há inativação de usuário; a única opção é excluir.

API de setores

Documentação técnica - Prumo

Base: `/api/sectors`.

GET /

Acesso: gerência. Retorna `[{ "id": 1, "nome": "Geral" }]` em ordem alfabética.

POST /

Acesso: suporte.

```
{ "nome": "Recepção" }
```

Remove espaços nas pontas. Se o nome já existir, devolve o setor existente; senão, cria. **Respostas:** `201` · `400` nome vazio.

Setores também são criados automaticamente quando um nome novo é informado no cadastro de usuário ou de manual.

Limitações

Não há rotas para renomear ou excluir setor.

API de sistemas

Documentação técnica - Prumo

Base: `/api/systems`.

GET /

Acesso: autenticado. Lista todos os sistemas em ordem alfabética. `manuals_count` conta só os manuais visíveis ao usuário (suporte e editor de conteúdo: todos; demais: ativos dos seus setores).

POST /

Acesso: suporte.

```
{ "nome": "Aliança PX", "resumo": "Procedimentos da operadora" }
```

`nome` obrigatório. **Respostas:** `201` · `400` sem nome.

PUT /{id}

Acesso: suporte. Aceita `nome` e/ou `resumo`; campos ausentes são mantidos e os textos são gravados sem espaços nas pontas. Os manuais continuam ligados ao sistema. **Respostas:** `200` · `400` com `nome` vazio · `404`.

DELETE /{id}

Acesso: suporte.

Respostas: `204` excluído · `409` existe manual vinculado ao sistema (a exclusão é bloqueada; os manuais **não** ficam sem sistema).

API de manuais e arquivos

Documentação técnica - Prumo

Base: `/api/manuals`.

GET /

Acesso: autenticado. Filtro opcional `?systemId=3`.

- Suporte e editor de conteúdo: todos os manuais (ativos e inativos).
- Operador e gerente de setor: somente manuais ativos dos setores do usuário (pode ter mais de um).

Cada item traz os dados do manual, `criado_por_nome`, os setores do manual (`sector_ids` e `sector_names`, em ordem alfabética) e, do usuário logado, `first_access_at`, `completed_at` e `progress_percent` (média entre páginas vistas do PDF e percentual assistido do vídeo, contando só o que o manual tem: com PDF e vídeo cada parte vale até 50%; com só um deles, ele vale 100%). Ordem: mais recentes primeiro.

GET /manage

Acesso: gerência (suporte, editor de conteúdo e gerente de setor). Lista da tela **Gerenciar Manuais**, com ativos e inativos, em ordem alfabética.

- Suporte e editor de conteúdo: todos os manuais.
- Gerente de setor: só os manuais cujos setores são **todos** seus. Um manual compartilhado com setor de outro gerente não aparece.

Cada item traz `id`, `titulo`, `descricao`, `system_id`, `system_name`, `active`, `version`, `has_pdf`, `has_video`, `created_at`, `updated_at`, `criado_por_nome`, `sector_ids` e `sector_names`. Não traz os caminhos dos arquivos.

GET /{id}

Acesso: autenticado. Suporte e editor de conteúdo abrem qualquer manual; os demais só manuais ativos dos seus setores. Sem acesso, responde `404` (não revela que o manual existe).

No modo `s3`, `pdf_url` e `video_url` voltam como **URLs assinadas temporárias** (validade `FILE_URL_TTL_SECONDS`, padrão 4 horas), geradas só depois de conferir o acesso. Na listagem (`GET /`) esses campos trazem a chave do objeto, que não abre o arquivo sozinha.

POST /

Acesso: gerência. Dois formatos:

- `multipart/form-data` com os arquivos nos campos `pdf` e `video` (modos `local` e `supabase`, ou arquivos pequenos);
- JSON com `pdfKey` e `videoKey` no lugar dos arquivos, depois do upload direto ao bucket (UPLOADS.md). É o formato usado pela tela no modo `s3`, e o único que aceita vídeos grandes no Cloud Run.

Campo	Tipo	Obrigatório	Observação
`titulo`	texto	Sim	Até 180 caracteres

Campo	Tipo	Obrigatório	Observação
`descricao`	texto	Não	
`systemId`	inteiro	Sim	Sistema existente
`sectorIds`	inteiros	Sim (salvo gerente com um só setor)	Um ou mais setores já cadastrados. No multipart, repita o campo (`-F sectorIds=2 -F sectorIds=5`); no JSON, envie uma lista. Gerente de setor só publica nos seus setores (com um setor, pode omitir); setor de fora responde `400`
`setor`	texto	Não	Formato antigo, com o nome de um único setor; usado só quando `sectorIds` não vem. Nele, o suporte cria o setor se não existir
`pdf`	arquivo	Pelo menos um dos dois	`application/pdf`
`video`	arquivo	Pelo menos um dos dois	MP4, WebM ou QuickTime

O manual pode ter só PDF, só vídeo ou os dois. Sem nenhum arquivo, responde `400` ("Envie pelo menos o PDF ou o vídeo"). No upload direto, vale o mesmo para `pdfKey` e `videoKey`.

Limites: PDF até 20 MB e vídeo até 200 MB (variáveis `UPLOAD_MAX_PDF_MB` e `UPLOAD_MAX_VIDEO_MB`). A tela também recusa vídeo com mais de 10 minutos; a API não confere a duração. Setor inexistente em `sectorIds` responde `400`; sem nenhum setor, responde `400` ("Selecione pelo menos um setor").

O manual aparece para quem é de **qualquer um** dos setores escolhidos. Os setores ficam na tabela `manual_sectors`; `manuals.sector_id` guarda só o primeiro da lista.

```
curl -X POST http://localhost:4000/api/manuals \
  -H "Authorization: Bearer TOKEN" \
  -F "titulo=Cadastro de paciente" -F "systemId=1" -F "sectorIds=2" -F "sectorIds=5" \
  -F "pdf=@manual.pdf;type=application/pdf" \
  -F "video=@treinamento.mp4;type=video/mp4"
```

Fluxo: confere os setores, grava os arquivos (PDF com neutralização de impressão automática) e insere o manual com os setores na mesma transação.

Respostas: `201` manual criado · `400` campo obrigatório ausente, tipo não permitido ou chave inválida/inexistente · `413` arquivo acima do limite.

O manual não tem questionário nem prazo. A avaliação é feita pelas provas (EXAMS.md).

Quem edita e exclui

`PUT /{id}` e `DELETE /{id}` valem para suporte, editor de conteúdo e gerente de setor, com esta regra (`canManageManual` em `utils/access.js`):

- Suporte e editor de conteúdo: qualquer manual.
- Gerente de setor: só manual cujos setores são **todos** seus. Se o manual também for de um setor que ele não tem, responde `403` ("Você só pode alterar manuais que sejam apenas dos seus setores"). Ao trocar os setores, ele só pode marcar os seus (`400` caso contrário).
- Operador: `403`.

Manual inexistente (ou id inválido) responde `404`. Cada alteração e exclusão grava auditoria (`manual_updated` ou `manual_deleted`, com o título em `details`).

`PUT /{id}`

Acesso: gerência, conforme a regra acima. Formato `multipart/form-data` ou JSON; todos os campos são opcionais: `titulo`, `descricao`, `systemId`, `sectorIds` (substitui a lista de setores) ou `setor`, `active` (`"true"` ou `"false"`), `pdf`/`pdfKey`, `video`/`videoKey`.

- Enviar `pdf` ou `video` gera nova versão: arquiva a versão e o progresso atuais, apaga o progresso ativo e incrementa `version` (regras em REGRAS-DE-NEGOCIO.md).
- `active: false` tira o manual da lista dos operadores e gerentes sem apagar o progresso; `active: true` devolve.

Respostas: `200` · `400` setor inválido ou de fora · `403` sem permissão para este manual · `404`.

`DELETE /{id}`

Acesso: gerência, conforme a regra acima. **Respostas:** `204` · `403` · `404`.

Remove em cascata os setores do manual, o progresso, as permissões e os históricos de versão e de progresso. Não há como desfazer; para só tirar o manual do ar, use `PUT` com `active: false`. Os arquivos no armazenamento **não** são apagados.

Arquivos

`GET /uploads/{pasta}/{arquivo}`

Acesso: público. Usado só no modo `local` (desenvolvimento): serve os arquivos de `backend/uploads` (`pdfs/` e `videos/`). No modo `supabase`, o banco guarda a URL pública do bucket. Nesses dois modos, quem tiver o link abre o arquivo sem login.

No modo `s3` o bucket é privado: o banco guarda a chave do objeto e o arquivo só abre pela URL assinada devolvida em `GET /{id}`.

API de upload direto

Documentação técnica - Prumo

Base: `/api/uploads`. Usada quando o backend está no modo `s3` (bucket compatível com S3, como o Cloudflare R2 do piloto). O navegador envia o PDF e o vídeo direto ao bucket por uma URL assinada; o backend só autoriza, assina e depois confere o arquivo ao salvar o manual.

`GET /config`

Acesso: gerência (suporte, editor de conteúdo ou gerente de setor).

Resposta `200`:

```
{ "directUpload": true, "driver": "s3", "limits": { "pdfMb": 20, "videoMb": 200 } }
```

`directUpload: false` (modos `local` ou `supabase`): a tela envia os arquivos no próprio `POST /api/manuals` em `multipart/form-data`.

`POST /presign`

Acesso: gerência. Corpo JSON:

Campo	Tipo	Observação
`kind`	`pdf` ou `video`	
`contentType`	texto	PDF: `application/pdf`. Vídeo: `video/mp4`, `video/webm` ou `video/quicktime`
`size`	inteiro	Tamanho em bytes; acima do limite responde `413`

Resposta `200`:

```
{
  "key": "videos/2f6c...e1.mp4",
  "method": "PUT",
  "url": "https://<conta>.r2.cloudflarestorage.com/<bucket>/videos/2f6c...e1.mp4?X-Amz-...",
  "headers": { "Content-Type": "video/mp4" },
  "expiresIn": 600
}
```

O navegador faz `PUT` do arquivo em `url` com os `headers` informados. Depois envia `key` como `pdfKey` ou `videoKey` no cadastro do manual (MANUALS.md).

Respostas: `200` · `400` tipo não permitido ou upload direto não configurado · `403` perfil sem permissão · `413` acima do limite.

Conferência ao salvar o manual

Ao receber `pdfKey`/`videoKey`, o backend confere no bucket:

- a chave segue o padrão `pdfs/<uuid>.pdf` ou `videos/<uuid>.<ext>` e está na pasta do campo certo;
- o objeto existe;
- o tamanho real está dentro do limite (se passar, o objeto é apagado e a resposta é `413`);

- o tipo é permitido;
- o PDF começa com `%PDF-` e tem a impressão automática neutralizada.

Não existe limite de duração do vídeo no servidor; a tela recusa vídeos acima de 10 minutos.

API de progresso e painel

Documentação técnica - Prumo

Base: `/api/progress`.

GET /{manualId}

Acesso: autenticado com visibilidade do manual. Retorna o progresso do próprio usuário. Sem registro ainda, devolve valores iniciais.

```
{
  "user_id": 5, "manual_id": 9,
  "pdf_completed": false, "video_progress": "34.50",
  "total_seconds": 180, "page_count": 10, "last_page": 4,
  "pages_viewed": [1, 2, 3, 4],
  "first_access_at": "2026-10-16T12:00:00.000Z",
  "last_access_at": "2026-10-16T12:10:00.000Z",
  "completed_at": null
}
```

`video_progress` vem como texto (tipo NUMERIC do PostgreSQL).

PUT /{manualId}

Acesso: autenticado com visibilidade do manual. Atualização incremental; todos os campos são opcionais.

```
{ "page": 4, "pageCount": 10, "videoProgress": 34.5, "seconds": 30, "pdfCompleted": false }
```

Regras aplicadas pelo servidor:

- cria o registro no primeiro envio;
- páginas são somadas ao conjunto já visto, sem repetir;
- `page_count` e `last_page` guardam o maior valor recebido;
- `videoProgress` limitado a 0–100 e nunca diminui;
- `seconds` limitado a 60 por chamada e acumulado;
- PDF concluído quando todas as páginas foram vistas **ou** quando `pdfCompleted: true` é enviado;
- manual concluído quando as partes que ele tem estão concluídas: PDF lido (se houver PDF) e vídeo >= 90% (se houver vídeo).

Resposta: o progresso consolidado (mesmo formato do `GET`).

Problema conhecido: como `pdfCompleted` e `videoProgress` são aceitos sem conferência, uma chamada direta marca o manual como lido e assistido.

GET /report

Acesso: gerência. Gerente de setor recebe só os próprios setores; suporte e editor de conteúdo recebem todos.

Uma linha por pessoa de **qualquer perfil** (operador, gerente de setor, editor de conteúdo e suporte) x manual: os manuais de cada setor dela, inclusive não iniciados, mais os manuais que ela abriu fora dos seus setores. Assim o suporte e o editor de conteúdo, que podem não ter setor, aparece nos manuais que leu. `sector_names` são os setores do manual pelos quais a pessoa o recebe (para quem abriu o manual por fora dos seus setores, todos os

setores do manual) e `sector_name` é a mesma lista separada por vírgula. Quem tem vários setores aparece uma vez por manual. Inclui manuais inativos.

Gerente de setor recebe só as pessoas que são dos próprios setores, nos manuais desses setores (a leitura do suporte não aparece para ele).

Campos: `user_id`, `user_name`, `user_role`, `sector_name`, `manual_id`, `manual_title`, `pdf_completed`, `video_progress`, `first_access_at`, `last_access_at`, `completed_at`, `total_seconds`, `page_count`, `pages_read`, `has_pdf`, `has_video`, `version`.

É a fonte do Painel de uso e da exportação CSV feita no navegador.

API de provas

Documentação técnica - Prumo

Base: `/api/exams`. Regras de negócio em REGRAS-DE-NEGOCIO.md. Tabelas em Banco de Dados.

Gerente de setor cria provas para um dos seus setores. Suporte e editor de conteúdo escolhem um setor ou todos os setores. Quem responde são os colaboradores (perfil `usuario`) do setor da prova, ou de todos os setores.

POST /

Acesso: gerência (gerente de setor, editor de conteúdo ou suporte). Formato JSON. Gerente de setor escolhe um dos seus setores em `sectorId`; se tiver só um, pode omitir.

Campo	Tipo	Obrigatório	Observação
`sectorId`	número ou `"todos"`	Depende	Suporte e editor de conteúdo: id do setor, ou `"todos"` (ou vazio) para todos os setores. Gerente de setor: id de um dos seus setores, obrigatório se tiver mais de um
`titulo`	texto	Sim	Até 180 caracteres
`descricao`	texto	Não	
`startsAt`	data e hora ISO 8601	Sim	Início do período de realização
`endsAt`	data e hora ISO 8601	Sim	Final do período; deve ser depois do início
`questions`	lista	Sim	De 1 a 10 perguntas, na ordem em que serão exibidas

Cada pergunta:

Campo	Múltipla escolha	Resposta aberta
`type`	`"multipla_escolha"`	`"aberta"`
`prompt`	enunciado	enunciado
`options`	4 textos, na ordem A, B, C, D	não enviar
`correctOption`	índice da correta: 0 (A) a 3 (D)	não enviar

```
{
  "titulo": "Prova de Faturamento - Outubro",
  "startsAt": "2026-10-20T11:00:00.000Z",
  "endsAt": "2026-10-21T21:00:00.000Z",
  "questions": [
    { "type": "multipla_escolha", "prompt": "Qual guia é usada para internação?", "options": ["SP/SADT",
"Internação", "Consulta", "Honorários"], "correctOption": 1 },
    { "type": "aberta", "prompt": "Descreva como conferir uma guia antes do envio." }
  ]
}
```

Respostas: `201` prova criada (com `question_count`) · `400` validação (mensagem indica o campo ou a pergunta) setor não encontrado, gerente sem setor ou fora dos seus setores · `403` perfil sem permissão.

GET /available

Acesso: autenticado. Para colaboradores, lista as provas dos seus setores e as de todos os setores que estão no período, ativas e ainda não entregues por ele, da que termina primeiro para a última. Para os demais perfis devolve `[]`.

```
[{ "id": 1, "titulo": "Prova de Faturamento - Outubro", "descricao": null, "starts_at": "...", "ends_at":
 "...", "question_count": 2 }]
```

É a fonte do pop-up de prova disponível e da tela **Provas**.

Ciclo da prova

A entrega (`exam_submissions`) tem `status`:

Situação	Quando
`em_andamento`	Colaborador clicou em **Iniciar prova** (`POST /{id}/start`)
`enviada`	Colaborador enviou as respostas (`POST /{id}/submissions`)
`encerrada`	Colaborador saiu da página antes de enviar (`POST /{id}/leave`), ou voltou para uma prova que tinha ficado em andamento

Uma prova em andamento só pode ser enviada ou encerrada. Abrir ou iniciar de novo uma prova em andamento a encerra sem respostas e responde `409` ("Esta prova foi encerrada porque você saiu da página antes de enviar."). Isso garante o bloqueio mesmo quando o navegador não consegue avisar a saída (queda de rede, travamento).

GET /{id}

Acesso: colaborador de um dos setores da prova (ou qualquer colaborador, se for para todos os setores). Devolve só os dados da tela de início, **sem** as perguntas.

```
{ "id": 1, "titulo": "...", "descricao": null, "starts_at": "...", "ends_at": "...", "question_count": 2
}
```

Respostas: `404` prova inexistente, de outro setor ou perfil diferente de colaborador · `409` fora do período, já entregue, já encerrada ou deixada em andamento (nesse caso ela é encerrada).

POST /{id}/start

Acesso: igual ao `GET /{id}`. Registra o início (`status = em_andamento`, `started_at`) e devolve as perguntas **sem** a alternativa correta.

```
{ "id": 1, "titulo": "...", "descricao": null, "starts_at": "...", "ends_at": "...",
  "questions": [{ "id": 7, "position": 0, "type": "multipla_escolha", "prompt": "...", "options": ["...",
 "...", "...", "..."] }] }
```

Respostas: `201` · `404` · `409` como no `GET /{id}`.

POST /{id}/leave

Acesso: colaborador com a prova em andamento. Corpo opcional `{ "answers": { ... } }`, no mesmo formato do envio. A tela chama esta rota ao sair da página (navegar no sistema, voltar, recarregar ou fechar) ou ao trocar de aba ou de janela, com `fetch` em modo `keepalive`.

Encerra a prova (`status = encerrada`) com as respostas recebidas; perguntas sem resposta não são gravadas e contam como erradas. **Respostas:** `204` · `409` prova não iniciada ou já finalizada.

POST /{id}/submissions

Acesso: colaborador do setor da prova, com a prova em andamento (sem iniciar, responde `409`). As chaves de `answers` são os IDs das perguntas. Múltipla escolha recebe o índice da alternativa (0 a 3); resposta aberta recebe o texto.

```
{ "answers": { "7": 1, "8": "Confiro carteirinha, CID e assinatura." } }
```

Resposta `201`:

```
{ "objectiveTotal": 1, "objectiveCorrect": 1 }
```

- Todas as perguntas precisam de resposta; faltando alguma, responde `400` indicando qual.
- Uma entrega por colaborador; depois de enviada ou encerrada, nova tentativa responde `409`.
- A nota considera só as perguntas de múltipla escolha.

GET /results

Acesso: gerência. Suporte e editor de conteúdo recebem todas. Gerente de setor recebe as dos seus setores e as de todos os setores; `collaborators` e `submissions` contam só colaboradores que pertencem a um dos setores dele. Ordenadas da mais recente para a mais antiga.

Cada prova traz `sector_name` ("Todos os setores" quando `sector_id` é nulo), `criado_por_nome`, `collaborators` (colaboradores do setor), `questions` (com `correct_option`) e `submissions`. Cada entrega traz `user_name`, `status` (`enviada`, `encerrada` ou `em_andamento`; em andamento depois do fim do período volta como `encerrada`), `objective_total`, `objective_correct`, `started_at`, `submitted_at` (nulo em andamento) e `answers` (`question_id`, `selected_option`, `answer_text`).

É a fonte da aba **Resultados de Provas** do Painel de uso.

API de aparência (white label)

Documentação técnica - Prumo

Base: `/api/branding`. Guarda as cores e as logos da plataforma na tabela `app_settings`, chave `branding`. Vale para todos os usuários.

GET /

Acesso: público (a tela de login também usa as logos). Resposta com `Cache-Control: no-cache`:

```
{
  "colors": { "sidebarStart": "#222a69", "primary": "#cc3399" },
  "logoLight": "...",
  "logoDark": "...",
  "updated_at": "2026-10-26T12:00:00.000Z"
}
```

Sem configuração salva, devolve `{ "colors": {} }` e as telas usam as cores e logos padrão. Só vêm as cores que foram alteradas; logos não enviadas não aparecem.

PUT /

Acesso: suporte. Substitui a configuração inteira (o que não for enviado volta ao padrão). Limite do corpo: 2 MB.

```
{
  "colors": { "sidebarStart": "#7a1f1f", "primary": "#0a7f5a", "title": "#5b2a86" },
  "logoLight": "...",
  "logoDark": null
}
```

Campo	Regra			
`colors`	Objeto opcional. Chaves aceitas abaixo; valor em hexadecimal `#rrggbb`. Chave desconhecida é ignorada; valor vazio ou nulo volta ao padrão			
`logoLight`	Logo sobre fundo escuro (sidebar). Data URL `...`, até 512 KB. Nulo ou vazio volta à logo padrão
`logoDark`	Logo sobre fundo claro (login e cabeçalho). Mesmas regras			

Chave de cor	Onde aparece
`sidebarStart`, `sidebarEnd`	Degradê do fundo da sidebar (topo e base)
`sidebarText`	Texto dos menus da sidebar
`sidebarHoverText`, `sidebarHoverBg`	Texto e fundo do menu ao passar o mouse ou selecionado
`primary`, `primaryHover`	Botões principais, normal e ao passar o mouse
`primaryText`	Texto dos botões principais
`title`	Títulos

Chave de cor	Onde aparece
`accent`	Destaques e links

Respostas: `200` com a configuração salva · `400` cor ou logo inválida, logo acima de 512 KB · `401` · `403` perfil sem permissão.

Cada gravação registra `branding_updated` em `audit_logs`, com as chaves de cor alteradas e se há logo própria.

Observações

- As cores viram variáveis CSS aplicadas na raiz da página. A tela guarda a última configuração no navegador (`localStorage`, chave `branding`) para não piscar as cores padrão ao abrir.
- Quem já está com a página aberta vê a mudança no próximo carregamento.
- SVG é aceito; o arquivo é exibido apenas em `<img>`, o que impede a execução de scripts embutidos.